ThreatReady - UI/UX, SEO, accessibility and performance corrections

Before/after comparison - 28 October 2026 - branch **feature/ui-ux-seo-accessibility-fixes** from **main @ 7d81555**

Each figure is marked by its source: **(M)** measured in this session on the local stack; **(A)** the 27 October audit's baseline, not re-measured here; **(S)** confirmed in source. The audit's own fixes were never committed, so **main** contained none of them; everything below was implemented afresh on this branch. **main** itself was not checked out, committed to, pushed or merged.

1. Public marketing site (threatready.io, 17 pages)

Area	Before (main)	After (this branch)
Web fonts	Google Fonts stylesheet + 2 preconnects on every page; about 1 s render-blocking on mobile (A); visitor IP sent to Google	Inter and JetBrains Mono variable fonts self-hosted in assets/fonts/ (SIL OFL licences included), Inter latin preloaded; 0 third-party requests (M)
Content-Security-Policy	Allowed fonts.googleapis.com and fonts.gstatic.com; six legal/trust pages still allowed the old backend host threatready-db.onrender.com (S)	Self-origin only for styles and fonts; stale host removed; the per-page inline-script hashes unchanged (S; check-landing-csp 17/17)
robots.txt / sitemap.xml	Neither existed (S)	robots.txt (Allow all + Sitemap) and a generated sitemap.xml of 16 canonical URLs, root first, no invented lastmod (S)
Canonical link	10 of 16 indexable pages (S)	16 of 16 (S)
Open Graph set (title, description, image, url)	8 complete, 2 partial, 6 missing (S)	16 of 16 complete; og:url equals the canonical (S)
twitter:card	10 pages (S)	16 of 16 (S)
Longest meta description	rubric.html: 270 characters (S)	149 characters, same facts (S); checker now caps titles at 80 and descriptions at 180
Product screenshots	1600 px WebP only, 18-71 KB each (M)	800 px variants of 7-29 KB with srcset/sizes on all 10 images; the 1600 px files stay for large or high-DPR screens (M)
Light theme: scoring heatmap (attack-reasoning-lab.html)	White text on a pale violet mix: 2.65-4.2:1 on 5 cells, WCAG 1.4.3 failure (A)	Solid #4636D6 behind the heavy cells: 7.6:1 with white (M, computed styles in the browser)
Light theme: 'weak' score badge (rubric.html)	--bad #C2403A on its tint: 4.32:1 (A)	--bad #B0362F: 5.45:1 on the badge, 6.15:1 on white (M)
Duplicate id on pilot.html	id="f-company" on the Organisation input and the footer heading, so the footer landmark took its name from an empty input (S)	Field renamed f-org (label updated; no script referenced it) (S)
Lighthouse 12.8 mobile, same machine back to back: main's site (:8091) vs this branch (:8090) - pricing.html	performance 88, FCP 2.8 s, LCP 2.8 s, render-blocking 898 ms, 1 third-party origin (M)	performance 95, FCP 1.6 s, LCP 1.8 s, render-blocking 150 ms, 0 third-party origins (M)
Same comparison - index.html	performance 80, render-blocking 334 ms, weight 349 KiB, CLS 0.107, TBT 36 ms, 1 third-party origin (M)	render-blocking 149 ms, weight 296 KiB, CLS 0.000, 0 third-party origins; but TBT 506 ms and performance 63 (M) - see note*
Lighthouse accessibility / SEO / best practices	100 / 100 / 89 (index; the demo's paste blocking, UX-01)	unchanged: 100 / 100 / 89

* Measured with the full development stack running on this Windows machine (Lighthouse benchmarkIndex 600-850, so absolute values are low; compare the two columns). The TBT rise on index did not appear on pricing or rubric and varied 1409 / 767 / 506 ms across runs; the likeliest mechanism is the font-display: swap re-layout of the heavy demo page under 4x CPU throttling. The audit measured the same change at 99/100 with 16 ms TBT on an idle Linux box. Treat the index figure as unconfirmed until re-measured on an idle machine or in

production.

2. Signed-in platform (onboard, InterviewPrep, Labs, Attack Reasoning, hosted labs)

Area	Before (main)	After (this branch)
Indexability	Every URL - sign-in, /app/profile, /labs/, /ar/, any made-up path - returned 200 with no noindex directive anywhere (A, S)	X-Robots-Tag: noindex on every gateway response (asserted on SPA, proxied, 404, upstream 500, gateway 500) and a noindex meta in all 9 app shells; crawling stays allowed so the directive is read (S, M)
Platform CSP	Allowed Google Fonts origins that no app uses (every app ships @fontsource) (S)	Removed from deploy/gateway.mjs, the generated _headers file and the Red Team CSP test; gateway test asserts no Google origins (S)
Tab titles (WCAG 2.4.2)	Onboard: 'ThreatReady' on every route. Attack Reasoning domain, attempt, summary and history pages and the Labs console: the app name only (S)	'Sign in - ThreatReady', 'Create account', 'Home', 'Profile', 'Admin console', 'User details - Admin' (no name or email), 'Sign out', 'Page not found'; 'Cloud Security - Attack Reasoning Lab', scenario title, 'Assessment summary', 'Your assessments'; 'The Compromised Startup - Lab Simulations' (M, read from the browser tab)
Unknown addresses (soft 404s)	Onboard silently redirected to sign-in; InterviewPrep silently to the dashboard (S)	Real 'Page not found' screens with the ways back, titled accordingly, in both apps (M). Labs and AR already had them. The HTTP status from the SPA host is still 200 (gateway 404 for unknown top-level paths left open)
Onboard JavaScript on the public sign-in page	One bundle containing the whole signed-in app and the admin console (S)	Main bundle + lazy chunks: ProductPage 1.7 KB, ProfilePage 1.9 KB, AdminPage 6.2 KB, AdminUserPage 3.6 KB, ModulePage 0.3 KB (gzip, build output); AdminGate stays inside the admin chunk; a short 'Loading' line while a chunk arrives (M)
/app/profile at 1440 px	Content capped at 1040 px inside the 1280 px shell, about 240 px short of the header and footer edges (A)	Uses the shell width; cards align with the header and footer (M, screenshot)
InterviewPrep dashboard at 390 px	Four KPI cards stacked full width; the page was 3,688 px tall (A)	Two KPIs per row (cards at x = 16 and 200, 174 px wide), 3,022 px tall, no horizontal overflow; one column again below 340 px (M)
Attack Reasoning tables at desktop	'83 - correct' and dates such as '21 Oct 2026, 15:08' wrapped onto two lines (A)	Score and date cells stay on one line; the scenario title is the cell that wraps (M)
InterviewPrep History empty state	h3 directly under the page h1 (axe heading-order) (S)	h2 through a new Empty level prop, identical look; unit test asserts the h2 (M)
InterviewPrep first screen in development	The h1 was focused on load because React StrictMode's double effect reset a first-run flag, drawing a focus ring (A)	The guard compares the last focused path; no focus on load, route changes still move focus to the new h1 (M)

3. Regression protection added

Gate	Before	After
Landing_Page-main/tools /check_site.py	Links, anchors, claims, app host, scroll regions	Plus: canonical = own URL, og:url = canonical, Open Graph and Twitter set, title <= 80 and description 50-180 and both unique, duplicate ids, every img with alt and width/height, no Google Fonts in HTML or CSS, robots.txt names the sitemap, sitemap.xml in sync with the indexable pages
test_site_tools.py	9 tests	12 tests (SEO tags and fonts; sitemap follows noindex and stays in sync; duplicate id)

Gate	Before	After
deploy/test/gateway.test.mjs	5 security headers asserted on every response kind	6: x-robots-tag: noindex added; CSP asserted free of Google origins
tools/gen-headers.mjs	Mirrored 4 gateway headers into the Cloudflare _headers file	5: X-Robots-Tag included; _headers regenerated
e2e/ui-audit.mjs	No sideways scrolling, consoles fit the viewport, axe WCAG 2.1 AA	Plus: every route must have a non-generic tab title; every app route must carry the noindex meta

4. Verification results after the changes (M)

Check	Result
check-landing-csp / gen-headers --check / tools self-test	PASS 17/17 - PASS - PASS 10/10
check_site.py --offline / site tool unit tests	PASS (17 pages) - PASS 12/12
deploy: gateway / launcher + child-env	PASS 49/49 - PASS 17/17 (state-mirror BLOCKED: needs a disposable PostgreSQL URL; labs-child NOT RUN: needs the esbuild bundle, blocked by npm install-scripts policy here)
onboard: typecheck (contracts, api, web) / build / unit tests	PASS - PASS (lazy chunks, no source maps) - PASS 6/6
InterviewPrep: typecheck (web, api) / build / vitest	PASS - PASS - 101 pass, 7 skipped, 1 pre-existing failure (avatar-asset.test.ts needs the licensed interviewer.glb, deliberately not in the repository)
Labs: typecheck / build / vitest	PASS - PASS - 91/93 (2 pre-existing environmental: security.test.ts A9 creates symlinks, EPERM without Windows symlink privilege)
Attack Reasoning: typecheck / build / vitest	PASS - PASS - 44/44 (one 5 s rate-limit timeout under four concurrent builds; 13/13 when re-run alone)
Red Team lab: typecheck	PASS
scripts: publish-check . / scripts tests	PASS - 1/3 (2 pre-existing Windows path failures 'S:\S:\...', 1 skipped: no rsync)
UI regression sweep e2e/ui-audit.mjs: 34 routes x 8 viewports, overflow + console fit + axe WCAG 2.1 AA + new title/noindex checks (Chrome 156)	766/806. Every overflow, console-fit, axe and title check passed. The 40 failures had one cause: the five hosted labs were served from dist/ folders built before this change (and the Labs API reads those shells once at boot), so the noindex meta was absent as served. Rebuilt as deploy/build.sh does and the API restarted; all five dist shells now carry the meta and the re-run at the two axe viewports passed 256/256
Browser checks (built-in browser, local stack)	Sign in, Home, Profile (1440 px), AR domain page (1440 px), both not-found screens, InterviewPrep dashboard and AR history (390 px), marketing AR and rubric pages in light theme; no console errors on the pages inspected
Manual assistive technology (NVDA, VoiceOver), keyboard-only walkthrough, real devices, 200-400% zoom	NOT RUN. Automated axe results are not a compliance claim

5. Local run

All services started from this checkout and answered: onboard http://localhost:5173 (API :3200, /api/health 200), InterviewPrep http://localhost:5174/interview-prep (API + worker :3100), Labs http://localhost:5175/labs/ (API :4000), Attack Reasoning http://localhost:5176/ar/ (API :4100), marketing site http://localhost:8090/, bundled PostgreSQL 16 on 127.0.0.1:55433 (no Docker on this machine). Both databases were migrated locally. Signed in with the repository's local development test account (a .test address from the gitignored .logs notes).

Not exercised (need credentials, email, OAuth, live LLM calls or an admin account): sign-up verification, password reset, Google/GitHub sign-in, an interview through to its report, an Attack Reasoning attempt through to evaluation (LLM_DRIVER=fake locally), admin console contents.

6. Left open, on purpose

Item	Why	Who
CONT-01: '[Registered Office Address]' (privacy.html, terms.html) and '[To be appointed]' (privacy.html)	Legal facts; not fabricated. Both pages are indexable and now in the sitemap. Alternative: add noindex to them and re-run tools/sync_shell.py, which drops them from the sitemap	Business / legal
SEO-06: 1200 x 630 social share image	Brand artwork	Brand
SEO-07: titles of 69-76 characters on 5 pages, descriptions of 172-175 on 2	Marketing copy; the checker now stops them growing further (80 / 180)	Marketing
PERF-04: code-splitting ThreatWall, Attack Reasoning, Red Team; PERF-05 logo re-export; PERF-06 Cloudflare browser TTL	Larger change; binary brand asset; Cloudflare access	Engineering / brand / ops
Deploy and submit	X-Robots-Tag takes effect on the Render host after deploy; robots.txt and sitemap.xml publish with the site; then submit the sitemap in Search Console and Bing Webmaster Tools	Owner
Windows checkouts	core.autocrlf=true turns the tree CRLF, which breaks the hash-based CSP check and gen-headers --check locally. A .gitattributes with '* text=auto eol=lf' would end that; not added without the owner's say	Owner

Full checklist, file list and reproduction commands: docs/UI_UX_SEO_FIXES_2026-10-28.md on the branch.